QUANTUM SECURITY INTELLIGENCE

Отчёт об аудите безопасности и постквантовой готовности

reddsa @ 04e973bcf8d4 · Zcash Foundation — публичный репозиторий (пассивная проверка)

Организация	QSI
Дата отчёта	2026-11-04 19:15 UTC
Версия отчёта	1
Запуск аудита	66dc426a-b0c7-4872-8381-1690c003ff22 · Документальный аудит · 2026-11-04 19:15 UTC
Версия анализатора	qsi-engine 1.3.0
Профиль риска	Криптобиржа, кастодиан или кошелёк
SHA-256 содержимого	`5ca6c9c5ed7313b21cef308aaed72429129f081cd89916ded12aeb8640a00654`
Ключ подписи (Ed25519, отпечаток SHA-256; подпись — отдельный файл report.sig.json)	`5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`

Содержание

1. Резюме для руководства
2. Область и границы проверки
3. Методология
4. Проверенные и непроверенные активы
5. Краткое описание архитектуры
6. Общая оценка состояния безопасности
7. Сводка находок по серьёзности
8. Подробное описание находок
9. Подтверждающие доказательства
10. Постквантовая оценка
11. Ограничения и допущения
12. План устранения проблем
13. Приоритеты на 30, 60 и 90 дней
14. Проверки после устранения
15. Использованные инструменты
16. Источники и нормативные документы
17. Приложения

Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.

Резюме для руководства

4	0	0	2	0
Всего находок	Критическая	Высокая	Средняя	Низкая

Классификация	Количество
Подтверждённая техническая уязвимость	0
Известная уязвимая версия компонента	0
Подтверждённая ошибка конфигурации	0
Потенциальный криптографический риск	0
Долгосрочный постквантовый риск	2
Рекомендация по улучшению	1
Недостаточность данных	1

Top 5

ID	Серьёзность	Подробное описание находок	Балл приоритета
QSI-2026-12470	Средняя	Квантово-уязвимый FROST: пороговая подпись и протоколы MPC (1 файл(ов)) предварительно	35.6
QSI-2026-12469	Средняя	Квантово-уязвимый RedDSA: роль не определена (3 файл(ов)) предварительно	34.2
QSI-2026-12472	Информационная	1 бюллетеней в 1 пакет(ах) crates.io, нужных только для разработки или сборки предварительно	15.5
QSI-2026-12471	Информационная	Не обнаружено криптобиблиотек с поддержкой PQC предварительно	13.3

Неравенство Моски (x + y > z): x = 10, y = 5, z = 8 → при этом сценарии миграция завершится слишком поздно. z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет. Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Область и границы проверки

Режим: Документальный аудит

Репозиторий: https://github.com/ZcashFoundation/reddsa @ 04e973bcf8d46819db055ebd0d44304c24a156a4 — ссылки в доказательствах открывают строки на этом коммите.

Предоставленные входные данные

Файл	Размер	SHA-256	Маскирования
Cargo.lock	30238	217f7f54967a76b15a91e0d0c3bccf5b3f067f3fcd77eab0d2acac4b405b9ecb	0
Cargo.toml	2180	1583dbe342f22d6c74c38285fbb41471faeb998d920394519798e1b454c979de	0
src/batch.rs	10206	a4fa2e3dcd45fb3dc060d8dcd0fe14dd6184383e04c6c8e08f4db763a72a8c4d	0
src/constants.rs	890	bf76bc1fe6375973a72af170f91f51ce1a34fc7b39b3c9f4b03ffa0ec90d419c	0
src/error.rs	1049	993754bf8dd056065f8ea7b1ac253fb330bd9fd520d27fe132625ec0d894116c	0
src/hash.rs	1622	96e2e2e0fb88bd1b25b07900a13c3f40590e0dac046ef46b1bef4ebb86fc561a	0
src/internal.rs	493	4cac9407db2114ae96fe24d0fcd029d22f66c8d2512cfbb0a4263121f19985be	0
src/lib.rs	4754	0e8171122eb4d548d709e8b1e86f56041d6ec618a72ca03b9df63d3f858bbf4d	0
src/messages.rs	11571	c562ab55a1fd8475000bdc7149193a3a8f8651077e57de8074508fcdb835e787	0
src/orchard.rs	4926	bbe653123789105467c177913fc8f84c1b1da6524eac8095d4c38b315b8f1c4a	0
src/sapling.rs	797	e1a79c4db2d7e3d7984a6bbdfdd3d915cbdec6509064b4b726f9b9b139e1cf51	0
src/scalar_mul.rs	8326	641a008b6d9d4c97649143b292c92b23b266c333c65fe5289722090fa2ed0854	0
src/signature.rs	1585	9c9bdf2359aad47f48db150a9ba781ccf2dcf0b91b05d0f0a11a1306b85fb8de	0
src/signing_key.rs	6963	a06db739109eea3939c6f5f5e6e704f0079cc298e83ce4e1ff103fa85a6a8aba	0
src/verification_key.rs	7478	173f8f563bcf59d253d8420ac55eb2d931b654f915a4922912878d5b09dc6584	0

Методология

Аудит выполнен движком QSI 1.3.0. Каждый анализатор формирует факты (правило, параметры, доказательства); тексты находок генерируются из каталога правил. Источники методики указаны в разделе «Источники и нормативные документы».

Приоритизация: объяснимая взвешенная модель (серьёзность, вероятность эксплуатации, доступность атакующему, влияние на конфиденциальность/целостность/доступность с весами профиля «Криптобиржа, кастодиан или кошелёк», критичность актива, срочность, простота устранения) с множителем уверенности. CVSS v3.1 применяется только к техническим уязвимостям с определённым вектором. Для долгосрочных квантовых рисков используется неравенство Моски; их серьёзность ограничена уровнем «Средняя», и они никогда не представляются как эксплуатируемые уязвимости.

Классификация находок: подтверждённая техническая уязвимость; известная уязвимая версия компонента (версия зависимости названа в бюллетене; затронутый код может не вызываться — это проверяется отдельно, а подтверждённая проверкой становится уязвимостью); подтверждённая ошибка конфигурации; потенциальный криптографический риск; долгосрочный постквантовый риск; рекомендация по улучшению; недостаточность данных. Находки на основе эвристик помечены как предварительные; решения аналитика показаны рядом с находками.

Покрытие проверок

Область	Статус	Подробности
dependencies	проверено	Cargo.lock: 130 dependencies parsed (130 pinned)
dependencies	проверено	Cargo.toml: 22 dependencies parsed (0 pinned)
source_code	проверено	src/batch.rs: 278 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/constants.rs: 24 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/error.rs: 35 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/hash.rs: 61 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/internal.rs: 14 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/lib.rs: 154 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/messages.rs: 277 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/orchard.rs: 157 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/sapling.rs: 27 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/scalar_mul.rs: 246 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/signature.rs: 55 lines scanned with 16 rule patterns and 145 registry patterns
source_code	проверено	src/signing_key.rs: 227 lines scanned with 16 rule patterns and 145 registry patterns; 29 lines in #[cfg(test)] modules ignored
source_code	проверено	src/verification_key.rs: 207 lines scanned with 16 rule patterns and 145 registry patterns

entropy	проверено	random-number generation: 13 code files read with 0 macro definitions from the tree; 0 ineffective guard(s), 0 weak random-bytes provider(s), 0 weak key-generation site(s)
osv_advisories	проверено	130 pinned packages queried at OSV.dev; 1 affected (1 of them only in development or build dependencies)

Проверенные и непроверенные активы

Предоставленные входные данные: 130 pinned packages queried at OSV.dev; 1 affected (1 of them only in development or build dependencies), Cargo.lock, Cargo.toml, random-number generation, src/batch.rs, src/constants.rs, src/error.rs, src/hash.rs, src/internal.rs, src/lib.rs, src/messages.rs, src/orchard.rs, src/sapling.rs, src/scalar_mul.rs, src/signature.rs, src/signing_key.rs, src/verification_key.rs

Краткое описание архитектуры

Static review of the source tree reddsa at 04e973bcf8d46819db055ebd0d44304c24a156a4. 15 files analysed; of 42 files, 9 are test, fuzzing, benchmark or example code and were left out, 18 are not read by any analyzer, 0 exceed the per-file limit and 0 did not fit the total limit. Files no analyzer reads include: .github/dependabot.yml, .github/release-drafter.yml, .github/workflows/coverage.yaml, .github/workflows/main.yml, .github/workflows/release-drafter.yml. 31 files in build-output or dependency-cache directories (.git, .hg, .venv, __pycache__, build, dist, node_modules, target, vendor, venv) were not read. No requests were sent to the owner's systems.

Общая оценка состояния безопасности

100
Ориентировочный индекс состояния (0–100)

44.4%
Доля квантово-уязвимых элементов инвентаризации

9
Криптографическая инвентаризация

Рассчитан по находкам в области проверки (подтверждённые и потенциальные проблемы, взвешенные по серьёзности). Ориентировочный; не сравним между аудитами с разной областью.

Сводка находок по серьёзности



ID	Подробное описание находок	Классификация	Серьёзность	Уверенность
QSI-2026-12470	Квантово-уязвимый FROST: пороговая подпись и протоколы MPC (1 файл(ов))	Долгосрочный постквантовый риск	Средняя	Средняя, предварительно
QSI-2026-12469	Квантово-уязвимый RedDSA: роль не определена (3 файл(ов))	Долгосрочный постквантовый риск	Средняя	Средняя, предварительно
QSI-2026-12472	1 бюллетеней в 1 пакет(ах) crates.io, нужных только для разработки или сборки	Рекомендация по улучшению	Информационная	Средняя, предварительно
QSI-2026-12471	Не обнаружено криптобиблиотек с поддержкой PQC	Недостаточность данных	Информационная	Средняя, предварительно

Подробное описание находок

QSI-2026-12470 · CODE-QV-ASYMMETRIC

Средняя

Квантово-уязвимый FROST: пороговая подпись и протоколы MPC (1 файл(ов))

Долгосрочный постквантовый риск | Уверенность: Средняя | предварительно — требует дополнительной проверки

6 упоминаний FROST в 1 файл(ах), например src/messages.rs:39. Роль по путям, именам функций и соседнему коду: пороговая подпись и протоколы MPC. Paillier, обязательства Педерсена и доказательства на дискретном логарифме внутри пороговых ECDSA и EdDSA ломаются алгоритмом Шора; постквантовая пороговая схема — это смена протокола, а не параметра.

Затронутый актив	source-code:FROST:threshold_mpc
Источник данных	src/messages.rs
Метод обнаружения	Сопоставление регулярных выражений с криптографическими API; роль определяется по словам в путях, именам охватывающих функций и строкам рядом с совпадениями.
Анализатор	source_code 1.3.0 · 2026-11-04 19:15 UTC
Балл приоритета	35.6 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=10.0, y=5.0, z=8.0 → при этом сценарии миграция завершится слишком поздно

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Долгосрочный риск зависит от назначения: подписи (подлинность до миграции) или обмен ключами/шифрование (ретроспективная расшифровка записанных данных).

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Откройте src/messages.rs:39 и проверьте приведённые строки; остальные файлы перечислены в доказательствах.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · src/messages.rs · line 39 · SHA-256 3ad3ca50bbcc97f8… · Файл c562ab55a1fd8475…

```
  38 |
  39 | impl<S: SpendAuth> From<frost::Commitment<S>> for Commitment {
  40 |     fn from(value: frost::Commitment<S>) -> Commitment {
```

file_excerpt · src/messages.rs · line 40 · SHA-256 65d226a68df2d189… · Файл c562ab55a1fd8475…

```
  39 | impl<S: SpendAuth> From<frost::Commitment<S>> for Commitment {
  40 |     fn from(value: frost::Commitment<S>) -> Commitment {
  41 |         // TODO(str4d): We need to either enforce somewhere that these messages are only
```

file_excerpt · src/messages.rs · line 228 · SHA-256 62a5b176caa27cd4… · Файл c562ab55a1fd8475…

```
 227 |
 228 | impl<S: SpendAuth> From<SigningPackage> for frost::SigningPackage<S> {
 229 |     fn from(value: SigningPackage) -> frost::SigningPackage<S> {
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня. Эвристическое сопоставление шаблонов в исходном тексте без анализа потоков данных. Контекст использования (влияет ли на безопасность) требует ручного подтверждения; находка предварительная.

РЕКОМЕНДАЦИЯ

Отслеживайте постквантовые пороговые подписи (NIST IR 8214C) и держите слой протоколов готовым к замене схемы подписи; зафиксируйте, сколько должны жить ключи и доли.

ПОВТОРНАЯ ПРОВЕРКА

Повторите инвентаризацию после рефакторинга.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

QSI-2026-12469 · CODE-QV-ASYMMETRIC

Средняя

Квантово-уязвимый RedDSA: роль не определена (3 файл(ов))

Долгосрочный постквантовый риск | Уверенность: Средняя | предварительно — требует дополнительной проверки

8 упоминаний RedDSA в 3 файл(ах), например src/lib.rs:39. Роль по путям, именам функций и соседнему коду: роль не определена. По коду не видно, что защищают ключи; приоритет определит проверка.

Затронутый актив	source-code:RedDSA:general
Источник данных	src/lib.rs
Метод обнаружения	Сопоставление регулярных выражений с криптографическими API; роль определяется по словам в путях, именам охватывающих функций и строкам рядом с совпадениями.
Анализатор	source_code 1.3.0 · 2026-11-04 19:15 UTC
Балл приоритета	34.2 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо
Неравенство Моски (x + y > z)	x=10.0, y=5.0, z=8.0 → при этом сценарии миграция завершится слишком поздно

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Долгосрочный риск зависит от назначения: подписи (подлинность до миграции) или обмен ключами/шифрование (ретроспективная расшифровка записанных данных).

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Откройте src/lib.rs:39 и проверьте приведённые строки; остальные файлы перечислены в доказательствах.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

file_excerpt · src/lib.rs · line 39 · SHA-256 e05154e9a56cf4aa… · Файл 0e8171122eb4d548…

```
   38 | /// An element of the protocol's scalar field used for randomization of public and secret keys.
```

```
39 | pub type Randomizer<S> = <S as private::Sealed<S>>::Scalar;
40 |
```

file_excerpt · src/lib.rs · line 66 · SHA-256 aed9696d7fe2dfdf… · Файл 0e8171122eb4d548…

```
65 | /// A trait corresponding to `SpendAuthSig` in Zcash protocols.
66 | pub trait SpendAuth: SigType {}
67 |
```

file_excerpt · src/orchard.rs · line 39 · SHA-256 2a63a6db8262d595… · Файл bbe6531237891054…

```
38 | #[derive(Copy, Clone, PartialEq, Eq, Debug)]
39 | pub enum SpendAuth {}
40 | // This should not exist, but is necessary to use zeroize::DefaultIsZeroes.
```

file_excerpt · src/orchard.rs · line 46 · SHA-256 cd85b4b9b8ff5ecf… · Файл bbe6531237891054…

```
45 | }
46 | impl SigType for SpendAuth {}
47 | impl super::SpendAuth for SpendAuth {}
```

file_excerpt · src/orchard.rs · line 58 · SHA-256 7775dc8a2ccad06c… · Файл bbe6531237891054…

```
57 | }
58 | impl SigType for Binding {}
59 | impl super::Binding for Binding {}
```

file_excerpt · src/sapling.rs · line 7 · SHA-256 8c20e0abac671bec… · Файл e1a79c4db2d7e3d7…

```
 6 | #[derive(Copy, Clone, PartialEq, Eq, Debug)]
 7 | pub enum SpendAuth {}
 8 | // This should not exist, but is necessary to use zeroize::DefaultIsZeroes.
```

file_excerpt · src/sapling.rs · line 14 · SHA-256 ce98bcc2f0a6961c… · Файл e1a79c4db2d7e3d7…

```
13 | }
14 | impl SigType for SpendAuth {}
15 | impl super::SpendAuth for SpendAuth {}
```

file_excerpt · src/sapling.rs · line 26 · SHA-256 6145abb25ce349b5… · Файл e1a79c4db2d7e3d7…

```
25 | }
26 | impl SigType for Binding {}
27 | impl super::Binding for Binding {}
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Это прогнозный риск, зависящий от появления криптографически значимого квантового компьютера (CRQC). Публично известных CRQC сегодня нет; сроки неопределённы. Это не уязвимость, эксплуатируемая сегодня. Эвристическое сопоставление шаблонов в исходном тексте без анализа потоков данных. Контекст использования (влияет ли на безопасность) требует ручного подтверждения; находка предварительная.

РЕКОМЕНДАЦИЯ

Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на постквантовый алгоритм; введите уровень абстракции для криптогибкости.

ПОВТОРНАЯ ПРОВЕРКА

Повторите инвентаризацию после рефакторинга.

P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997); NIST IR 8547 — Transition to Post-Quantum Cryptography Standards; M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018)

QSI-2026-12472 · DEP-ADVISORY-DEV

Информационная

1 бюллетеней в 1 пакет(ах) crates.io, нужных только для разработки или сборки

Рекомендация по улучшению | Уверенность: Средняя | предварительно — требует дополнительной проверки

OSV.dev сообщает 1 бюллетеней (0 с оценкой high или critical) для 1 пакет(ов) crates.io, которые подтягивают только инструменты разработки или сборки (Cargo.lock): например, bincode@1.3.3 [dev]: RUSTSEC-2025-0141. Манифесты помечают их так (devDependencies, "dev": true в package-lock.json, [dev-dependencies]/[build-dependencies] через граф Cargo.lock), поэтому в поставляемый продукт они не входят.

Затронутый актив	dependencies:crates.io:non-runtime
Источник данных	OSV.dev
Метод обнаружения	Запрос OSV.dev querybatch по точным версиям; область применения — из devDependencies, флагов dev в package-lock.json, разделов importers в pnpm, графа Cargo.lock от таблиц Cargo.toml и — для yarn.lock, который область не записывает вовсе — графа файла блокировки, пройденного от package.json. Если рабочее требование в файле блокировки разрешить не удалось, файл остаётся без классификации, чтобы пакет не был отложен в сторону по ошибке.
Анализатор	dependencies 1.3.0 · 2026-11-04 19:15 UTC
Балл приоритета	15.5 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Пользователей продукта они не затрагивают. Они могут влиять на машины разработчиков и CI (цепочка поставки): скомпрометированный или уязвимый инструмент способен изменить сборку.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Найдите пакеты из доказательства на https://osv.dev и проверьте их область применения в Cargo.lock.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

tool_output · OSV.dev (crates.io) · Cargo.lock · SHA-256 92b1213d0f610917…

```
bincode@1.3.3 [dev]: RUSTSEC-2025-0141
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Данные получены от OSV.dev в зафиксированное время. Области применения взяты из манифестов; собственные build-зависимости крейтов реестра в Cargo.lock не различимы, поэтому множество runtime может оказаться больше реального, но не меньше.

РЕКОМЕНДАЦИЯ

Обновите инструменты в рамках планового обслуживания; в первую очередь пакеты, которые выполняются в CI с секретами или создают релизные артефакты.

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование зависимостей после обновления.

OSV.dev — open-source vulnerability database and API

QSI-2026-12471 · DEP-NO-PQC-LIBRARY

Информационная

Не обнаружено криптобиблиотек с поддержкой PQC

Недостаточность данных | Уверенность: Средняя | предварительно — требует дополнительной проверки

В 2 манифестах зависимостей QSI нашёл криптобиблиотеки (bls12_381, jubjub, pasta_curves), но ни одной из списка поддерживающих PQC.

Затронутый актив	dependencies
Источник данных	dependency manifests
Метод обнаружения	Сопоставление названий зависимостей.
Анализатор	dependencies 1.3.0 · 2026-11-04 19:15 UTC
Балл приоритета	13.3 / 100 (Криптобиржа, кастодиан или кошелёк)
CVSS v3.1	неприменимо

ВОЗМОЖНЫЕ ПОСЛЕДСТВИЯ

Только индикатор готовности: поддержка PQC может обеспечиваться платформой (OpenSSL, ОС, облачный KMS), а не зависимостями приложения.

ШАГИ ВОСПРОИЗВЕДЕНИЯ

```
Изучите перечисленные в доказательстве манифесты.
```

ПОДТВЕРЖДАЮЩИЕ ДОКАЗАТЕЛЬСТВА

dependency · Cargo.lock, Cargo.toml · SHA-256 075b070bd87081d3…

```
Crypto libraries: bls12_381, jubjub, pasta_curves
```

ОГРАНИЧЕНИЯ ПРОВЕРКИ

Отсутствие доказательств не является доказательством отсутствия: системные библиотеки и транзитивные зависимости могут не указываться.

РЕКОМЕНДАЦИЯ

Определите источник поддержки PQC (TLS-терминатор, KMS/HSM, обновление библиотек).

ПОВТОРНАЯ ПРОВЕРКА

Повторите сканирование после обновлений.

FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM); FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA)

Подтверждающие доказательства

ID	Тип	Источник данных	SHA-256
QSI-2026-12470	file_excerpt	src/messages.rs (line 39)	3ad3ca50bbcc97f879d408d4ad39d2bdede892e7a9d850c58b48241992b2b359
QSI-2026-12470	file_excerpt	src/messages.rs (line 40)	65d226a68df2d189afb1eaf7f3707c4560aa92f6c002f53abef1424875081306
QSI-2026-12470	file_excerpt	src/messages.rs (line 228)	62a5b176caa27cd457d4164701bc6e4f624d99ea5ddd17734ec6ee4d4af8ec5e
QSI-2026-12469	file_excerpt	src/lib.rs (line 39)	e05154e9a56cf4aa5879e5015ea625e4b0609d7031c391602b6a94430ecbbd7f
QSI-2026-12469	file_excerpt	src/lib.rs (line 66)	aed9696d7fe2dfdf006f303ffe492cc9d23031cf01aa014b288d2d60e0796016
QSI-2026-12469	file_excerpt	src/orchard.rs (line 39)	2a63a6db8262d59550636d8be561a03c127d81e0df6bb4a50505772b9d8f5460
QSI-2026-12469	file_excerpt	src/orchard.rs (line 46)	cd85b4b9b8ff5ecf99380306f0320d14b675282fc54a510bab492740bcdd948d
QSI-2026-12469	file_excerpt	src/orchard.rs (line 58)	7775dc8a2ccad06c7bc81924918e253589f66c95749a17f63a42a8745fb55e6d
QSI-2026-12469	file_excerpt	src/sapling.rs (line 7)	8c20e0abac671beca5ba5446ada21d5ead436c57b5169019ad6ec95d3cbbb242
QSI-2026-12469	file_excerpt	src/sapling.rs (line 14)	ce98bcc2f0a6961c8dc1f8f8e589fb75d44de794a392e2945b741a7ba0c434c7
QSI-2026-12469	file_excerpt	src/sapling.rs (line 26)	6145abb25ce349b55814a6a97fda93c14c32044d2cfb405e7df16a90b8a9b83b
QSI-2026-12472	tool_output	OSV.dev (crates.io) (Cargo.lock)	92b1213d0f61091716e425a9a06466220ab9c470db4d48232eff3ef32c1a1443
QSI-2026-12471	dependency	Cargo.lock, Cargo.toml	075b070bd87081d3aa64ebb503bbde5e807966cd67ec60df515334137ed8c509

Постквантовая оценка

	Обмен ключами (x — сколько данные должны оставаться конфиденциальными; «собери сейчас, расшифруй потом»)	Подписи (x — сколько подписи и ключи должны оставаться доверенными)
Срок жизни данных/ключей x	10	10
Время миграции y	5	5
Принятое число лет до CRQC z	8 (early)	8
x + y − z	7 → при этом сценарии миграция завершится слишком поздно	7 → при этом сценарии миграция завершится слишком поздно

Допущения планирования: x для обмена ключами, x для подписей, y — значения по умолчанию профиля риска «Криптобиржа, кастодиан или кошелёк», а не данные клиента; с фактическими сроками клиента вывод может измениться.

Постквантовая зрелость: Уровень 0 из 4 — постквантовой криптографии нет

- Только классика — пороговая подпись и протоколы MPC: FROST (1 файл(ов))

Следующий шаг: Проведите инвентаризацию: где классическая криптография с открытым ключом защищает долгоживущие данные и ключи, и выберите первую миграцию — обычно гибридный обмен ключами TLS и обёрнутые ключи.

Уровни: 0 — нет; 1 — есть, но не подключено; 2 — используется вне критичных путей; 3 — гибрид в критичном пути; 4 — постквантовое по умолчанию в критичных путях (корень доверия, обёртка ключей, обмен ключами в канале). Оценка по коду и манифестам.

Что делают квантово-уязвимые алгоритмы

Роль	Алгоритмы (файлы)	ID	Первый шаг
пороговая подпись и протоколы MPC	FROST (1)	QSI-2026-12470	Отслеживайте постквантовые пороговые подписи (NIST IR 8214C) и держите слой протоколов готовым к замене схемы подписи; зафиксируйте, сколько должны жить ключи и доли
роль не определена	RedDSA (3)	QSI-2026-12469	Классифицируйте каждое использование, зафиксируйте сроки жизни данных и запланируйте миграцию на постквантовый алгоритм; введите уровень абстракции для криптогибкости

Роль определяется по путям файлов, именам функций и коду вокруг совпадений; проверка её подтверждает. Сначала — ключи корня доверия и обёрнутые ключи: их трудно заменить или можно записать уже сегодня.

z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

Квантовый статус	Количество
н/п	5
уязвим (Шор)	4

Подробное описание находок: QSI-2026-12470, QSI-2026-12469

Анкета постквантовой готовности

Анкета готовности для проекта не заполнялась.

Квантовые алгоритмы, значимые для этой инвентаризации

Квантовый алгоритм	Действие	Алгоритмы из инвентаризации (строк)	Что это значит для аудита
Алгоритм Шора — дискретный логарифм на эллиптических кривых Q1: квантовые вычисления офлайн, классический доступ к жертве	взламывает	FROST (1), RedDSA (3)	Ключи на эллиптических кривых, по оценкам, падут раньше ключей RSA сопоставимой классической стойкости. В блокчейнах первыми под угрозой монеты, чей открытый ключ уже опубликован (повторно используемые адреса, выходы pay-to-public-key и Taproot); планируйте переход на постквантовые подписи и до этого избегайте повторного использования ключей.

Действие: взламывает — алгоритм нужно заменить; ослабляет — более длинные ключи или выходы восстанавливают запас; учтено в стандартных параметрах — при стандартных наборах действий не требуется; только при суперпозиционных запросах — к обычному применению неприменимо.

Ограничения и допущения

- Отчёт содержит результаты автоматизированного и документального анализа в указанных границах. Он не является юридическим заключением, сертификацией или подтверждением соответствия какому-либо стандарту.
- z — плановое допущение профиля риска, а не прогноз. Публично известного криптографически значимого квантового компьютера сегодня не существует.

План устранения проблем

QSI-2026-12470 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования FROST в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-12469 · P3 · 90 дн. краткосрочное снижение риска

Внесите использования RedDSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).

Обоснование	Без понимания, где и зачем используется алгоритм, миграцию невозможно спланировать.
Ожидаемый результат	У каждого использования есть владелец, срок жизни и путь миграции.
Сложность	medium
Зависимости	Доступ к владельцам систем.
Побочные эффекты	Нет (документация и проектирование).
Тесты до изменения	Подтвердите соответствие записи развёрнутой конфигурации.
Тесты после изменения	Инвентаризация согласована владельцем системы.
Условие закрытия	Существует запись инвентаризации с владельцем, сроком жизни и целевым алгоритмом.

QSI-2026-12470 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию FROST на Как для обычной схемы, которую она порождает: ML-DSA или SLH-DSA там, где это допускает проверяющая сторона; пороговые постквантовые подписи пока в стадии исследований (NIST IR 8214C) (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.

Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование Как для обычной схемы, которую она порождает: ML-DSA или SLH-DSA там, где это допускает проверяющая сторона; пороговые постквантовые подписи пока в стадии исследований (NIST IR 8214C) или гибридной схемы.

QSI-2026-12469 · P4 · 90 дн. устранение первопричины

Запланируйте миграцию RedDSA на (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.

Обоснование	Устраняет зависимость от квантово-уязвимого примитива с открытым ключом.
Ожидаемый результат	Актив использует стандартизированный NIST постквантовый или гибридный алгоритм.
Сложность	high
Зависимости	Поддержка в библиотеках/протоколах (например, OpenSSL ≥ 3.5, прошивки HSM), совместимость с контрагентами.
Побочные эффекты	Больший размер ключей/подписей, возможное влияние на производительность и совместимость.
Тесты до изменения	Тесты совместимости на стенде.
Тесты после изменения	Проверьте фактически используемый алгоритм на рабочем активе.
Условие закрытия	Повторный аудит показывает использование или гибридной схемы.

QSI-2026-12472 · P4 · 90 дн. устранение первопричины

Обновите зависимости разработки и сборки из доказательства.

Обоснование	Устраняет первопричину, описанную в находке.
Ожидаемый результат	При повторной проверке слабость не обнаруживается.
Сложность	low
Зависимости	Окно изменений и согласование владельца.
Побочные эффекты	Обновление инструментов может изменить результат сборки; сравните релизные артефакты.
Тесты до изменения	Воспроизведите находку по описанным шагам.
Тесты после изменения	Выполните процедуру повторной проверки из находки.
Условие закрытия	Сканирование не сообщает бюллетеней для пакетов инструментов, либо оставшиеся зафиксированы.

Приоритеты на 30, 60 и 90 дней

30 дн.

Приоритет	ID	Действие	Тип
Нет			

60 дн.

Приоритет	ID	Действие	Тип
Нет			

90 дн.

Приоритет	ID	Действие	Тип
P3	QSI-2026-12470	Внесите использования FROST в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P3	QSI-2026-12469	Внесите использования RedDSA в source code в криптографическую инвентаризацию с владельцем и оценкой срока жизни данных; обеспечьте криптографическую гибкость (идентификаторы алгоритмов, конфигурируемые провайдеры).	краткосрочное снижение риска
P4	QSI-2026-12470	Запланируйте миграцию FROST на Как для обычной схемы, которую она порождает: ML-DSA или SLH-DSA там, где это допускает проверяющая сторона; пороговые постквантовые подписи пока в стадии исследований (NIST IR 8214C) (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины
P4	QSI-2026-12469	Запланируйте миграцию RedDSA на (или гибридную схему) после появления поддержки в библиотеках, протоколах и у контрагентов.	устранение первопричины
P4	QSI-2026-12472	Обновите зависимости разработки и сборки из доказательства.	устранение первопричины

Проверки после устранения

ID	Повторная проверка
QSI-2026-12470	Повторите инвентаризацию после рефакторинга.
QSI-2026-12469	Повторите инвентаризацию после рефакторинга.
QSI-2026-12472	Повторите сканирование зависимостей после обновления.
QSI-2026-12471	Повторите сканирование после обновлений.

Использованные инструменты

Tool	Version
blockchain	1.0.0
certificates	1.2.0
chain_map	1.0.0
configs	1.1.0
dependencies	1.3.0
inventory_document	1.1.0
solidity	1.3.0
source_code	1.4.0
tls_code	1.1.0
tls_live	1.0.0
qsi-engine	1.3.0
OSV.dev API	v1

Источники и нормативные документы

Reviewed: 2026-10-13

1. C. Chevignard, P.-A. Fouque, A. Schrottenloher — Reducing the Number of Qubits in Quantum Discrete Logarithms on Elliptic Curves (IACR ePrint 2026/280) — IACR ePrint. https://eprint.iacr.org/2026/280 (revision of a EUROCRYPT 2026 paper: 3.12n + o(n) qubits; for n = 256, 1193 qubits and 22 runs of 2^38.98 Toffoli gates)
2. Common Vulnerability Scoring System v3.1: Specification Document — FIRST. https://www.first.org/cvss/v3.1/specification-document (final)
3. D. Litinski — How to compute a 256-bit elliptic curve private key with only 50 million Toffoli gates (arXiv:2306.08585) — arXiv. https://arxiv.org/abs/2306.08585 (preprint (2023-06-14): 6000 modules × 1152 physical qubits, one key per 10 minutes under its architecture assumptions)
4. FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM) — NIST. https://csrc.nist.gov/pubs/fips/203/final (final (August 2024))
5. FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA) — NIST. https://csrc.nist.gov/pubs/fips/204/final (final (August 2024))
6. FIPS 205 — Stateless Hash-Based Digital Signature Standard (SLH-DSA) — NIST. https://csrc.nist.gov/pubs/fips/205/final (final (August 2024))
7. J. Proos, C. Zalka — Shor's discrete logarithm quantum algorithm for elliptic curves (Quantum Inf. Comput. 3(4), 2003; arXiv:quant-ph/0301141) — Quantum Information & Computation. https://doi.org/10.26421/QIC3.4-3 (peer-reviewed article)
8. M. Cain et al. — Shor's algorithm is possible with as few as 10,000 reconfigurable atomic qubits (arXiv:2603.28627) — arXiv. https://arxiv.org/abs/2603.28627 (preprint (2026-03-30): P-256 in a few days with 26,000 physical neutral-atom qubits; RSA-2048 one to two orders of magnitude longer)
9. M. Mosca — Cybersecurity in an Era with Quantum Computers: Will We Be Ready? (IEEE Security & Privacy, 2018) — IEEE. https://doi.org/10.1109/MSP.2018.3761723 (peer-reviewed article; source of the x + y > z migration inequality)
10. M. Roetteler, M. Naehrig, K. Svore, K. Lauter — Quantum resource estimates for computing elliptic curve discrete logarithms (ASIACRYPT 2017) — IACR / arXiv. https://arxiv.org/abs/1706.06752 (peer-reviewed article: at most 9n + 2⌈log2 n⌉ + 10 qubits and 448 n^3 log2 n + 4090 n^3 Toffoli gates)
11. NIST IR 8547 — Transition to Post-Quantum Cryptography Standards — NIST. https://csrc.nist.gov/pubs/ir/8547/final (final (2026-10-27; the initial public draft of November 2024 is obsoleted). Tables 2 and 4: ECDSA, EdDSA and RSA signatures, finite-field and elliptic-curve DH and MQV, and RSA key establishment are deprecated after 2030 and disallowed after 2035 at every key size — the draft deprecated only the 112-bit level. A composite (hybrid) key establishment stays FIPS 140-validatable while one input comes from an approved scheme. Repeats the federal deadlines of OMB M-26-15: post-quantum key establishment by 2030-12-31 and signatures by 2031-12-31 for high value assets and high impact systems)
12. OSV.dev — open-source vulnerability database and API — Open Source Security Foundation. https://osv.dev/ (the database QSI queries for each exactly pinned version; every advisory id in a finding resolves at https://osv.dev/vulnerability/<id>)
13. P. W. Shor — Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer (SIAM J. Comput., 1997) — SIAM. https://doi.org/10.1137/S0097539795293172 (peer-reviewed article)
14. R. Babbush et al. — Securing Elliptic Curve Cryptocurrencies against Quantum Vulnerabilities: Resource Estimates and Mitigations (arXiv:2603.28846) — arXiv. https://arxiv.org/abs/2603.28846 (preprint (2026-03-30, v2 2026-04-15): 256-bit ECDLP with < 1200 logical qubits and < 90 M Toffoli gates (or < 1450 and < 70 M); < 500,000 physical qubits at 10^-3 error, minutes)

Приложения

A. Криптографическая инвентаризация

Алгоритм	Параметр	Расположение	Квантовый статус	Классический статус
Crypto library jubjub (jubjub)	0.11.1	Cargo.lock	н/п	допустимо
Crypto library pasta_curves (pasta_curves (Pallas/Vesta))	0.6.0	Cargo.lock	н/п	допустимо
Crypto library bls12_381 (bls12_381)	0.9.0	Cargo.lock	н/п	допустимо
Crypto library jubjub (jubjub)	0.11	Cargo.toml	н/п	допустимо
Crypto library pasta_curves (pasta_curves (Pallas/Vesta))	0.6	Cargo.toml	н/п	допустимо
FROST		src/messages.rs:39	уязвим (Шор)	допустимо
RedDSA		src/lib.rs:39	уязвим (Шор)	допустимо
RedDSA		src/orchard.rs:39	уязвим (Шор)	допустимо
RedDSA		src/sapling.rs:7	уязвим (Шор)	допустимо

B. JSON

qsi.report/1 · SHA-256 5ca6c9c5ed7313b21cef308aaed72429129f081cd89916ded12aeb8640a00654